In Kubernetes (K8s), access control is a critical part of securing your cluster 🛡️. It determines **who can do what** on which resources. Kubernetes provides multiple layers and methods for access control:

---

## 🔑 1. Authentication

Determines *who* is making the request.

- **User Accounts** (for humans, managed outside the cluster)
- **Service Accounts** (for apps running inside the cluster)
- Supported methods:
    - Certificates
    - Tokens (JWT, service account tokens)
    - OpenID Connect (OIDC)
    - Webhooks

---

## 🛂 2. Authorization

Determines *what* actions are allowed.

### ✅ Role-Based Access Control (RBAC)

Most widely used method 👇

- **Role** – Defines permissions (verbs: get, list, create, etc.) within a namespace.
- **ClusterRole** – Similar to Role but cluster-wide.
- **RoleBinding** – Assigns a Role to a user/service account within a namespace.
- **ClusterRoleBinding** – Binds ClusterRole cluster-wide.

Example: Grant `read-only` access to pods in a namespace.

```yaml
kind: Role
apiVersion: rbac.authorization.k8s.io/v1
metadata:
  namespace: my-namespace
  name: pod-reader
rules:
- apiGroups: [""]
  resources: ["pods"]
  verbs: ["get", "list", "watch"]
```

---

## 🚪 3. Admission Controllers

They intercept requests *after* authentication & authorization.

- **ValidatingAdmissionWebhook** – Enforce policies (e.g., no privileged containers)
- **MutatingAdmissionWebhook** – Modify requests (e.g., inject sidecars)

Common tools:

- **OPA Gatekeeper** 🔐
- **Kyverno** 🛡️

---

## 🕶️ 4. Network Policies

Control **pod-to-pod** communication at the network level 🔗.

- Define *which pods* can talk to *which other pods/services*
- Implemented by CNI plugins (like Calico)

---

## 🔏 5. API Server Access Controls

Secure access to the API server:

- **kubeconfig** files with TLS certs
- **API server flags** to control access (`--anonymous-auth`, `--authorization-mode`)

---

## 🧠 Summary Table

| Layer | Purpose | Tool/Method |
|---|---|---|
| Authentication | Identify user/app | Certificates, Tokens, OIDC |
| Authorization | Allow/deny actions | RBAC, ABAC, Webhook |
| Admission Control | Enforce policies | OPA, Kyverno, Webhooks |
| Network Policies | Pod communication control | CNI plugins (Calico) |
| API Server Settings | Restrict cluster entry points | TLS, kubeconfig |

---